



Uber 2022 Breach

CASE STUDY

How an 18-year-old spent under \$100 on the dark web and walked away with the keys to one of the world's largest technology companies — in under two hours.

Step One: Buying the Keys

15 SEPTEMBER 2022

The attacker, an 18-year-old affiliated with the **Lapsus\$ extortion group**, began with a simple, low-cost purchase. On a dark web marketplace, he acquired the username and password of an Uber EXT (external contractor) account — likely for under **\$100 USD**.

These credentials had been harvested by malware running on the contractor's **personal device**. A browser on that device had cached corporate credentials, and the malware silently exfiltrated them. Uber had no visibility into this. They had no idea their contractor's credentials were listed for sale. The attack had not yet begun, and already the perimeter had been breached.



Steps Two & Three: Push Fatigue and Social Engineering

The MFA Bombardment

The stolen credentials worked — but Uber enforced MFA. A push notification was sent to the real contractor's phone. He was **asleep at home**. He denied it. The attacker tried again. And again. For over an hour, push after push, the contractor swiped deny. Then he woke up, irritated and fatigued.

The Social Engineering Kill Shot

The attacker pivoted. He contacted the contractor on **WhatsApp**, impersonating Uber IT support, and offered a plausible explanation: *"We're seeing these prompts because we're pushing a security update — please approve to make them stop."* The exhausted contractor approved one prompt. Session established. MFA bypassed. VPN access granted.

⚠ This technique — known as **MFA fatigue** or **prompt bombing** — is a well-documented and increasingly common attack pattern. Push-based MFA alone is insufficient protection against a determined social engineer.

Step Four: The Script on the Share

Now inside Uber's VPN with a legitimate, MFA-passed session, the attacker began lateral movement. He scanned the internal network and found a **PowerShell script on a network share** — reachable from a contractor VPN session.

What the Script Contained

Hardcoded credentials for an **admin account on Uber's PAM solution** — the Privileged Access Management vault that held every other privileged credential in the environment.

Why It Was There

The script had been written **three years earlier** to automate a credential rotation task. The author had not anticipated — or considered — that the share would be reachable from a contractor VPN session.

The Consequence

A single hardcoded string in a forgotten script **defeated the entire purpose** of the PAM architecture. The vault built to protect all privileged access was now fully open.

Step Five: Total Compromise

With PAM admin access, the attacker downloaded credentials for every major platform in Uber's environment. What followed was a **complete enterprise takeover** — achieved in roughly two hours from initial sign-in to detection.



AWS & GCP

Cloud infrastructure credentials exfiltrated



OneLogin (IdP)

Identity provider fully compromised



Slack & GitHub

Internal comms and source code repositories accessed



Bug Bounty Platform

Active security reports defaced and exposed

📋 Uber detected the intrusion when staff began reporting an all-caps Slack message announcing the breach — posted by the attacker himself. **Dwell time: approximately two hours.**

The Attack Chain at a Glance

Five steps. Each one exploiting a different control failure. Each one made possible by the step before it.



What is striking is that no single step required exceptional technical skill. The attacker exploited predictable human behaviour, a forgotten script, and a misconfigured network boundary. The sophistication was organisational, not technical.

What Failed: Mapping the Controls

Every control failure in the Uber breach maps directly to a known best practice. This was not an unknown attack class — it was a textbook execution of well-documented techniques against well-documented weaknesses.

1 **Credential Management**
Hardcoded admin credentials in a PowerShell script with no rotation — a **cardinal sin** of credential hygiene. Scripts on shared network drives are not secret stores.

2 **MFA Type Selection**
Push-based MFA is vulnerable to **fatigue attacks and social engineering**. The contractor approved under duress. FIDO2 hardware keys are not susceptible to prompt bombing — there are no prompts to bomb.

3 **Least Privilege & Segmentation**
A contractor VPN session should **not have reached internal admin script shares**. The network boundary between contractor access and internal resources was insufficiently enforced.

4 **Conditional Access**
A sign-in from a **new IP, unusual time, contractor account, elevated risk score** — any single one of these signals should have triggered step-up authentication or a block. None did.

5 **Breach Credential Monitoring**
The contractor's credentials had been listed on the dark web for an **unknown period** before exploitation. No monitoring was tied to the account to surface this exposure proactively.

Discussion Questions

STRUCTURED DEBRIEF

Question 1

Which single control would most reliably have prevented the initial compromise?

Model answer: Phishing-resistant MFA — specifically **FIDO2 hardware keys** for VPN access. The purchased password would have been useless. No push prompts exist in FIDO2, so prompt bombing cannot occur. The social engineering would have had nothing to act on.

Question 2

Once inside, what enabled lateral escalation?

Model answer: Three compounding failures: (a) contractor account with broad network reachability, (b) hardcoded admin credentials in a script accessible from that session, and (c) those credentials being for the **PAM admin** — defeating the vault's entire purpose. Any one alone is a finding. Together, they are catastrophic.

Question 3

As vCISO advising post-incident, what three changes would you mandate?

Model answer: (1) FIDO2 hardware keys mandatory for VPN, IdP, and PAM access. (2) Zero-tolerance policy on credentials in code, enforced via **automated secret-scanning** in CI/CD pipelines and on file shares. (3) Network segmentation preventing contractor sessions from reaching internal admin shares.

The Pattern No One Can Ignore

Contractor identity is the soft underbelly of every enterprise. In every breached organisation listed here, the bar for contractors was lower than for full-time staff. That asymmetry is the vulnerability.

Lesson 1 — Target (2013)

HVAC contractor credentials used to pivot into the payment network. Retail. USA.

Lesson 2 — Medibank (2022)

Contractor account with no MFA. Health insurance. Australia.

Lesson 4 — Uber (2022)

Contractor with push MFA, fatigued into approval. Rideshare. USA.

Three different industries. Three different countries. Three different years. **The same root cause class.** When you return to your organisation after this course, ask one question: is the identity security bar for your contractors equal to that for full-time staff — or lower?

Key Takeaways

LESSONS LEARNED



Deploy Phishing-Resistant MFA

Push notifications are a social engineering surface. FIDO2 hardware keys eliminate prompt bombing, MFA fatigue, and credential phishing in a single control. Mandate them for VPN, IdP, and PAM access at minimum.



Secrets Do Not Belong in Scripts

Automated secret-scanning in CI/CD pipelines and on file shares is non-negotiable. A credential hardcoded into a forgotten PowerShell script three years ago should have been caught the same day it was written.



Segment Contractor Access Rigorously

A contractor VPN session should reach only the resources explicitly required by the engagement — nothing more. Broad internal network reachability for third parties is an acceptance of unquantified risk.



Monitor for Breached Credentials Continuously

Integration between your IdP and breach-credential intelligence feeds (HaveIBeenPwned-style) should surface compromised accounts before an attacker exploits them — not after a Slack announcement.